

Credential Compromise in a Healthcare Environment

Hands-on threat hunting across live enterprise telemetry — KQL & Microsoft Defender

Author: Latasha Seth · CompTIA Security+ · github.com/LatashaSeth | **Environment:** Log(n) Pacific Cyber Range · Sentinel + MDE · KQL

Conducted in the Log(n) Pacific cyber range — a hands-on SOC training environment built on live, raw enterprise telemetry. Nimbus Health is a fictional organization; the range environment and its telemetry are real.

Executive Summary

A billing analyst account (`j.morris`) was flagged for unusual activity and referred for a “stale-access housekeeping” review. Telemetry told a different story: the account was **driven remotely over RDP from external, public IPs using valid credentials** — not an employee at the billing desk. The operator ran systematic reconnaissance, pivoted to the file server, **fabricated a fraudulent approved invoice, tampered with the billing audit trail, and systematically collected HR and payroll data belonging to other employees.**

Root cause was *not* an insider mistake and *not* malware. It was **credential compromise / account takeover by an external actor** — provable by what was *absent*: no dropped binaries, no exploitation, only native tools and valid credentials throughout.

Scope & Method

Field	Detail
Environment	Log(n) Pacific cyber range — live enterprise telemetry
Estate / scope	Windows nh-* hosts (billing, HR, IT, file server); window 08-18 Mar 2026
Telemetry	Sentinel + MDE: DeviceLogonEvents, DeviceProcessEvents, DeviceFileEvents

Approach: filter-first scoping to window and hosts; baseline normal before hunting; cut application noise from operator activity (parent-process is the key tell); pivot across logon → process → file tables and across hosts; and reason from absence. Conclusions are anchored in observable evidence, with inference kept distinct.

Key Findings

1 — The account was driven from outside the building

Successful sessions were `RemoteInteractive` (RDP) logons from **external, public IPs** (labeled `Public` by Windows) — not the desk logons a real analyst produces. First crack in the “insider” story.

```
DeviceLogonEvents
| where DeviceName startswith "nh-wks-bill-01" and AccountName == "j.morris"
| where ActionType == "LogonSuccess" and LogonType == "RemoteInteractive"
| summarize Sessions = count() by RemoteIP, RemoteIPType
| sort by Sessions desc
```

→ See `01-external-rdp-sources.png`

2 — Noise ruled out, then the recon burst

The earliest deletions were **OneDrive updating itself** (its own version folders, launched by `explorer.exe` in sub-second bursts) — noise, not the intruder. Past it, the operator ran a deliberate discovery burst: `whoami` → `hostname` → `net use` → `net view` → `net view \\NH-FS-01` — orientation collapsing onto one named target, the file server. A later burst widened with `net view /domain:nimbus` and an `nslookup/arp` subnet sweep (T1033, T1069, T1087, T1135).

```
DeviceProcessEvents
| where DeviceName startswith "nh-" and AccountName == "j.morris"
```

```
| where FileName in~ ("whoami.exe","hostname.exe","net.exe","net1.exe",
"nslookup.exe","arp.exe")
| project Timestamp, FileName, ProcessCommandLine | sort by Timestamp asc
```

→ See 03-recon-burst.png

3 — Lateral movement, and a red herring proven by absence

The account opened RDP onto two hosts: `nh-fs-01` (file server) and `nh-wks-it-01` (IT box). Rather than assume, I proved the IT hop was empty — filtering its process activity showed **only automatic first-logon / session-setup activity**, `system-launched`, nothing the user ran. *Absence is a finding*: the real impact was all on the file server.

```
DeviceProcessEvents
| where DeviceName has "nh-wks-it-01"
| where InitiatingProcessAccountName == "j.morris"
| where FileName !in~ ("userinit.exe","unregmp2.exe","taskhostw.exe",
"smartscreen.exe","explorer.exe","rdpclip.exe","tstheme.exe")
| project Timestamp, FileName, ProcessCommandLine | sort by Timestamp asc
```

→ See 04-red-herring.png

4 — Impact on the file server: fraud & tampering

On `nh-fs-01` (where `RequestAccountName` carries the real actor), the account acted far outside its role: it **fabricated a fake approved invoice** (created a blank file, renamed it to impersonate an approved invoice, wrote content), **tampered with the audit trail** (`review_audit_20260311.txt`, T1070), and ran `whoami /groups` then `net share` to inventory access. Fraud + anti-forensics + abuse of an over-privileged account.

5 — Systematic cross-department data collection

The final phase reached into HR/Payroll: the account opened another employee's payroll review (`payroll_review_dpatel`) and, in the same burst, a **non-payroll** HR file (`quarterly_awards_shortlist`) with no fraud value — characterizing this as **systematic collection of multiple HR data types, not a single opportunistic grab** (T1005). Payroll was also staged in billing folders under a disguised `.txt.txt` name.

```
DeviceFileEvents
| where DeviceName has "nh-fs-01" and FolderPath has "HR"
| where InitiatingProcessAccountName == "j.morris"
or RequestAccountName == "j.morris"
| project Timestamp, FolderPath, FileName, ActionType | sort by Timestamp asc
```

→ See 06-hr-collection.png

MITRE ATT&CK Mapping

Tactic	Technique · ID	Evidence
Initial Access	Valid Accounts · T1078	External actor using valid credentials of a normal account
Lateral Movement	Remote Services: RDP · T1021.001	RemoteInteractive logons; pivots to IT box & file server
Discovery	Owner/User · T1033 · Groups · T1069	<code>whoami</code> , <code>whoami /groups</code>
Discovery	Account · T1087 · Shares · T1135 · System · T1018	<code>net user</code> , <code>net view /domain</code> , <code>net share</code> , <code>nslookup/arp</code>
Collection	Data from Local System · T1005	Payroll + awards files collected in one burst
Defense Evasion	Indicator Removal · T1070	Modification of the billing audit trail

Root Cause & Control Gaps

The honest read

Credential compromise / account takeover by an external actor using the valid credentials of a normal account, driven in

over RDP from external sources. Not an insider (external source), not malware (no dropped binaries), not exploitation (valid credentials throughout). The absence of malware and exploitation is precisely what proves it.

Control gaps (basis for a companion GRC analysis):

- **Least privilege / separation of duties (AC-6, AC-5)** — a submissions account had write access to the Approved sign-off stage and reach into HR/Payroll.
- **Audit-log integrity (AU-9)** — the audit trail was modifiable by a non-reviewer.
- **Remote access & boundary protection (AC-17, SC-7)** — external RDP reached internal workstations.
- **Identity & monitoring (IA-2, SI-4)** — valid-credential misuse from an external source raised no alert; MFA would have broken the takeover.

Work performed in the Log(n) Pacific cyber range for skills development. The range environment and telemetry are real; Nimbus Health is a fictional organization.